

Activity 2

Role-Based Functional Prototype

Secure Software Development (SSD) - Final Submission

Project Name	ScholarAssist - Secure Scholarship Assistance Management System
Group Members	Not provided
Live Project	https://abubakar-netizen.github.io/scholarassist/
Repository	https://github.com/Abubakar-netizen/scholarassist

1. Selected Roles and Responsibilities

Role	Functions
Student / Applicant	Search scholarships; evaluate eligibility; submit applications and track own application status.
Scholarship Review Officer	Review the application queue; inspect submission and document counts; update application status.

2. Demo Users and Functional Login

The login form matches an email/password pair against a local demo account record. The role is assigned from the matched account; there is no independent role selector.

Role	Demo email	Demo password
Student	student@university.edu.pk	Student#2026
Scholarship Review Officer	officer@scholarassist.edu.pk	Officer#2026

These are public, hard-coded demonstration credentials only. Do not reuse real passwords or enter real personal information.

3. Role-Specific Dashboards

Student / Applicant

- Search and filter scholarship opportunities.
- Evaluate eligibility using CGPA, household income, domicile, and scholarship rules.
- Attach demo documents, submit an application, and track only the signed-in student's applications.
- See their own CNIC in their student session.

Scholarship Review Officer

- Review submitted applications and inspect application references and document counts.
- Change application status to Under Review, Approved, or Rejected.
- See the applicant CNIC only in masked form in the review queue.

4. Restricted Function and Data Protection

Restricted function: changing an application status. **Authorized role:** Scholarship Review Officer. The update function checks the current signed-in role before changing application data. A student or guest receives an Access Denied message; the denied attempt is logged and the application remains unchanged.

Selected sensitive information: student CNIC. The student sees their own CNIC in the student dashboard and application form. The officer review queue displays a masked value (35202-*****-1).

5. Logout and Session Handling

Logout clears the active in-memory demo user, temporary uploaded documents, and displayed profile/eligibility values; hides both dashboards; resets login fields; and navigates to the login view. A guest cannot enter the protected portal.

6. Test Results

Test	Observed result	Result
Valid student login	Student dashboard opens with student profile, own CNIC, scholarship search, eligibility calculator, and personal tracker.	PASS
Valid officer login	Officer dashboard opens with review queue and status-update controls; student dashboard is hidden.	PASS
Different role interfaces	Student and officer see different functions and application views.	PASS
Wrong role attempts status update	Student cannot change status; Access Denied is shown, application stays unchanged, and event is logged.	PASS
Officer updates status	Officer can approve/reject or set Under Review; updated status appears in the student tracker.	PASS
CNIC privacy	Student sees own CNIC; officer queue shows masked CNIC (35202-*****-1).	PASS
Logout	Active user, temporary uploads, and displayed profile values are cleared; protected dashboards are hidden and login is shown.	PASS
Invalid credentials / guest portal	Invalid credentials are rejected; unauthenticated portal navigation redirects to login.	PASS

7. Security Development Note

Security concept applied: Role-Based Access Control (RBAC), least privilege, and data minimization.

Where applied: Credential-based role assignment and separate dashboards; officer-only status update guard; own-CNIC display for the student and masked CNIC in the officer queue.

What changed: Added demo users, credential matching, distinct dashboards, a guarded update, masked applicant data, logout/session clearing, and access-denied audit events.

Unauthorized attempt: The requested status change is blocked, Access Denied is shown, the application remains unchanged, and an access-denied event is recorded.

8. Verification and Deployment

Browser-tested both demo accounts, invalid credentials, guest portal redirection, dashboard separation, student denial of status updates, officer status updates, status visibility in the student tracker, masked officer CNIC, and logout clearing. No browser JavaScript errors were observed. JavaScript syntax checks, editor diagnostics, and git diff whitespace checks passed.

Deployed commit: 7b4706f30d697b431f13e097ad56af70d4ac69b0. GitHub Pages deployment workflow completed successfully.

Prototype Security Limitation

This is a static, client-side course prototype. Demo credentials, role checks, application state, uploads, and audit events can be inspected or modified in the browser. Client-side authorization and masking do not secure real data. Production use requires server-side authentication and authorization, protected session management and persistence, server-side upload validation, and durable audit logging. Do not use real credentials or personal information.